CS5292 · WEEK 5 · MODULE 3 · RELEASE BEFORE WEEK 6

What good looks like: RFI, evidence and control justification

Based on the assessor's final maturity assessment of the source institution, sanitised. All five were assessed "Y". Control 5 (1.4.1) is one of the Control Principles new in C-RAF 2.0. The "reviewer's challenge" rows show what a sharper reviewer would still question — credit students who spotted them.

1 · 1.1.1 Board and senior management oversight · Baseline · RFI row #1

"Designated members of management or an appropriate Board Committee are held accountable to the Board for implementing and managing cybersecurity and business continuity programmes."

Part A — what to request (in class)	Evidence to reference (pack refs)	Result
– List of management functions / committees responsible for cybersecurity and for business continuity (e.g. RMCC, IT steering committee, BCM committee), with member list (name and position) and Terms of Reference. – Board resolution or delegation designating who is accountable for the cybersecurity programme and the business continuity programme. – Business continuity policy and plan showing roles and approval. – Minutes showing these parties reporting back to the Board.	– RMCC Terms of Reference (D02) – Group Business Continuity Management Policy (D03) – Business Continuity Plan (D04)	Y

Control justification (final assessment, sanitised)

The Risk Management and Compliance Committee (RMCC) covers the Hong Kong headquarters, branches and representative offices. It is appointed by the Board and has authority to conduct any enquiry and review, and take actions it considers appropriate, on risk management and regulatory compliance matters — including cyber risk (duty d), cybersecurity policies (duty i) and significant cybersecurity issues (duty k). The CEO is a member, supported by the CRO, and the RMCC reports regularly to the Board (duty h).

The Group BCM Policy defines the scope, objectives, roles and responsibilities, principles and standards for business continuity, including incident reporting and escalation. The Head of IT, as Group BCP Officer, oversees implementation with the support of the IT security team; the policy is reviewed by the RMCC and approved by the Board.

Reviewer's challenge — what is still open

– The RMCC ToR requires annual review but the latest version is September 2023 — ask for evidence of the 2024 and 2025 reviews.
– Business continuity ownership is not consistent: the BCM Policy (D03) makes the Head of IT the Group BCP Officer who develops the BCP; the BCP itself (D04) is owned by the Group Head of Business Operations and approved by the Executive Committee. Who is accountable to the Board?
– The ToR names the committee, not the management owner of the cybersecurity programme. That sits in the Group Cyber Security Policy, which is not in the pack.

2 · 1.1.1 Board and senior management oversight · Baseline · RFI row #2

“Cybersecurity risks are included as agenda items in management meetings when prompted by highly visible cyber events or regulatory alerts. These updates may be presented by a senior representative with Technology Risk Management, Cybersecurity or Information Security function.”

Part A — what to request (in class)	Evidence to reference (pack refs)	Result
– Meeting minutes and packs (with attendee lists) of management and Board committee meetings that covered cybersecurity topics in the last 12 months. – An example of an agenda item prompted by a highly visible cyber event or a regulatory alert. – Who presents cyber updates, and how the presenter is briefed by IT / information security.	– RMCC Terms of Reference, duties (d), (i), (k) (D02) – RMCC Report Q1 2025 — cyber section (D05) – RMCC Report Q2 2025 — cyber section (D06) – RMCC minutes Q1 2025, item 6.2.9 (D07) Also cited by the assessor, not available to the class: – Group Cyber Security Policy (describes the CRO’s delegation to the Head of IT and Head of Compliance)	Y

Control justification (final assessment, sanitised)

At the quarterly RMCC meetings, highly visible cyber events and regulatory alerts are included as agenda items and presented by the CRO, with support from the Head of IT as required. The RMCC includes management such as the CEO. The risk dashboard and key risk metrics are standing agenda items, highlighting the current risk status and trends in information security and in the legal and regulatory environment — for example the Q1 2025 pack reports 65 blocked CEO-impersonation emails and the progress of EDR deployment.

The CRO delegates the monitoring of highly visible cyber events and regulatory alerts to the Head of IT and the Head of Compliance, who ensure the CRO has sufficient detail to report to the quarterly RMCC or to ad hoc meetings with senior management.

Reviewer’s challenge — what is still open

– The RMCC is a Board committee; the CP asks about management meetings. Executive Committee minutes with cyber items would be stronger evidence.
– The delegation from the CRO to the Head of IT and Head of Compliance is described in the Group Cyber Security Policy, which the assessor cited but is not in the pack — the RFI should still ask for it.
– Ask for an ad hoc example: what happened after a widely reported global incident or an HKMA circular?

3 · 1.1.3 Regular reporting · Baseline · RFI row #16

“Management provides a written report on the overall status of the cybersecurity (including cyber incidents) and business continuity programmes to the Board or an appropriate Board Committee at least annually.”

Part A — what to request (in class)	Evidence to reference (pack refs)	Result
– Reports on the overall status of the cybersecurity and business continuity programmes submitted to the Board or a Board committee in the last 12 months. – The reporting frequency, and the KRIs / metrics used. – Board or committee minutes showing the reports were received and discussed.	– RMCC Terms of Reference, duty (h) (D02) – Group Business Continuity Management Policy (D03) – RMCC Reports Q1 and Q2 2025 — cyber sections (D05, D06) – Draft IT KRIs, Aug 2025 (D10) – KRI report to the Q1 2026 RMCC / Board meeting (not in the pack — request it) Also cited by the assessor, not available to the class: – Group Cyber Security Policy	Y

Control justification (final assessment, sanitised)

A security risk metrics dashboard is produced quarterly and presented by the CRO, with support from the Head of Compliance and the Head of IT, at RMCC meetings. It covers the bank’s risk status and trends, the risk dashboard, and KRIs covering the cybersecurity and business continuity programmes.

Cybersecurity metrics include incident management, training completion and staff at higher risk of phishing from simulation exercises, and cyber incidents, if any. BCM-related metrics include operational outages caused by human error or unsuccessful IT changes, and major IT service disruptions affecting all staff, including high-profile system disruptions.

Reviewer’s challenge — what is still open

– Cyber reporting is clearly quarterly and written (D05, D06). Business continuity status (BIA, BCP test and call-tree results) does not appear in either 2025 pack — the KRI evidence from Q1 2026 is needed to close this.
– The KRIs were still a draft in August 2025, with tolerances “TBC” (D10). When were they approved, and by whom?
– The RMCC is a Board committee, so reporting to it satisfies the CP; the Board minutes noting the RMCC report would confirm it reaches the Board.

4 · 1.2.2 Policies · Baseline · RFI row #28

“Policies commensurate with the AI’s cyber risk and complexity are in place to address the concepts of incident response and resilience.”

Part A — what to request (in class)	Evidence to reference (pack refs)	Result
– Cyber / information security policy; cyber risk management policy. – Cybersecurity incident response plan (and crisis management guideline). – Business continuity management policy, BCP and disaster recovery plan. – For each: the version in force, approval record, and last review date.	– Group IT Security Incident Response Plan (D08) – Group Business Continuity Management Policy (D03) – Business Continuity Plan (D04) – Cyber Risk Management Policy — draft (a distractor: not approved) (D09) – Internal Audit follow-up tracker, action 2023-14 (D15) Also cited by the assessor, not available to the class: – Group Cyber Security Policy (the overarching policy)	Y

Control justification (final assessment, sanitised)

Policies commensurate with the bank’s cyber risk and complexity address incident response and resilience. (The assessor also relied on the Group Cyber Security Policy for the overarching principles; it is not in the class pack.)

The Group IT Security Incident Response Plan sets out the incident management process for IT staff responsible for restoring service outages and disruptions and for managing IT service providers. The Group BCM Policy sets out operational resilience requirements, including business continuity, crisis management and technology recovery.

Reviewer’s challenge — what is still open

– The Incident Response Plan is not a clean approved document: the cover says version 2.0, the details table says 1.2, and the approval and effective dates are placeholders “[DD MMM YYYY]”. The text says the Executive Committee approves it; the history table says “[Committee / Board]”. Ask for the approved, signed-off version.
– The Cyber Risk Management Policy (D09) is a v1.0 “first draft” with no approval date. It cannot be relied on as an approved policy.
– Cross-check D15: Internal Audit closed action 2023-14 (“obtain approval of the Incident Response Plan”) in January 2025 — yet the plan in the pack still has placeholder approval fields. Which version did IA see?
– The Group Cyber Security Policy — the overarching document — was not provided. Without it, the “policies” conclusion rests on a plan and a BCM policy.

5 · 1.4.1 Audit scope · Baseline · RFI row #51

“An audit is performed regularly to provide the Board of Directors and Senior Management with an independent and objective opinion of the adequacy and effectiveness of the AI’s cyber risk management, governance, and controls relative to its existing and emerging cyber risks and threats.”

Part A — what to request (in class)	Evidence to reference (pack refs)	Result
– Latest internal audit report(s) of the past 12 months with a cybersecurity focus, performed by internal or external auditors, with findings and recommendations. – Approved audit plan for the current / upcoming year showing the cyber topics — and how “emerging” risks (e.g. supply-chain compromise) are considered. – Internal Audit charter / policy and Audit Committee Terms of Reference (independence, reporting line). – Audit Committee minutes or IA quarterly reports showing the cyber audit results reached the Committee and the Board, and the issue follow-up log.	– Audit Committee Terms of Reference, duties (h), (i), (u) (D11) – Internal Audit Policy (D12) – Board minutes approving the 2024 and 2025 IA plans (D13) – Internal Audit report — Cybersecurity, 3 Mar 2025 (D14) – IA follow-up tracker (D15) – Three lines of defence (Internal Audit as third line) (D01)	Y

Control justification (final assessment, sanitised)

Internal Audit, as the third line of defence, provides an independent and objective opinion to senior management and the Board through the Audit Committee. It has a direct reporting line to the Audit Committee (D11 §1; D12). Audits follow an annual risk-based plan recommended by the Audit Committee and approved by the Board — the 2024 plan explicitly included Cybersecurity (D13).

The resulting Internal Controls Review — Cybersecurity (D14, 3 March 2025) tested network and endpoint security, including penetration testing and simulated attacks across 30 MITRE ATT&CK techniques, and rated six findings (four Medium, two Low) with management responses, owners and dates. Reports go to the auditee’s hierarchy (Head of IT, VP Information Security, CRO, Head of Compliance); the Head of IA reports quarterly to the Audit Committee on activities, significant issues and follow-up (D12), and the tracker shows 2023 cyber actions closed (D15).

Reviewer’s challenge — what is still open

– “Regularly”: cybersecurity is in the 2024 plan but not in the 2025 plan (D13). Ask for the 2026 plan, and for the rationale for skipping a year — or show that the 2025 third-party / vendor audit covered cyber supply-chain risk (the “emerging” threat this CP added in 2.0).
– “Opinion”: the provider’s disclaimer says the work “does not constitute an audit … we provide no audit opinion” (D14). Is it the independent opinion the CP asks for? The Head of IA’s own conclusion to the Audit Committee would close this.
– No Audit Committee minutes or IA quarterly report are in the pack — evidence that the cyber report actually reached the Committee and the Board is inferred from the ToR and Policy, not seen.
– Document hygiene again: the IA Policy is v1.0 from 2019 despite an annual review requirement; it says the Audit Committee approves the plan while the Board minutes show the Board approving it; the Q1 2025 minute is headed “2026 Internal Audit Plan” but describes 2025.

Reading across the five

- The assessor concluded “Y” on all five. The design is sound: a Board-appointed RMCC with cyber in its duties, quarterly written cyber reporting, documented incident response and BCM, and an independent Internal Audit function reporting to the Audit Committee.
- A few documents carry many Control Principles — the RMCC ToR, the BCM Policy and, at the source institution, an overarching Group Cyber Security Policy that is not in the pack. When one document carries many conclusions, check its version, approval and review date — and say so when it is missing.
- The weak points are document hygiene: overdue ToR and policy reviews, an Incident Response Plan with placeholder approval fields (which Internal Audit had marked approved), an unapproved v1.0 Cyber Risk Management Policy, draft KRIs, and a year with no cyber audit in the plan.
- Cross-referencing is where marks are won: D15 against D08, D13 against D12, D14’s disclaimer against the wording of CP 1.4.1.
- A “Y” can still carry recommendations. In the real report, these become observations for management to tidy up before the next cycle.